

API Security in the Age of AI and Microservices

Your APIs are doing more than ever. So are the people trying to break them.



A couple of months back, a friend of mine called me looking a bit shaken. He runs a small SaaS, maybe a thousand customers, nothing huge. Their API had been quietly leaking data for about three weeks before anyone noticed. Not a hack in the dramatic Hollywood sense. No firewall got smashed through. No zero-day exploit. Somebody had just figured out that one of their endpoints accepted a customer ID in the URL and didn't bother checking whether the person making the request owned that ID. So they wrote a tiny script. Looped through IDs one through fifty thousand. Pulled down whatever came back.

What got me wasn't the breach itself. It was how ordinary it was. No movie villain. No nation-state actor. Just a bored person with *curl* and a text editor. And here's the thing that really sticks with me. With AI tools today, you don't even need to bore someone with *curl*. You can ask a model to write

the script, point it at any API, and walk away while it goes hunting.

That's where we are now. APIs are the connective tissue of pretty much every product anyone ships. Microservices talk to each other through them. Mobile apps depend on them. Partners integrate through them. AI agents are starting to use them autonomously, which is its own can of worms. And the attackers have new tools too.

So let's talk about what's changed, and what you can do about it that doesn't require a security budget you don't have.

The world your API lives in now

A few years ago, when you said 'API', you usually meant a single backend serving a single frontend. Maybe a couple of mobile clients too. The traffic was mostly humans clicking buttons, the shape was predictable, and you had a decent sense of who your callers were.

That's not the world anymore. Today your typical mid-sized product might have anywhere from ten to a hundred microservices, all calling each other constantly. There's a public API for partners. There's a mobile app. There's a webhook system pushing events out to integrations. There's maybe an internal automation that hits your endpoints from a queue worker. And now, increasingly, there are AI agents calling your API on behalf of users, making decisions you didn't anticipate, and stringing together requests in ways no human ever would.

Each of these callers has different needs, different risk profiles, different ways of misbehaving. And every single one of them is a door into your system.

The old model of "I'll just put authentication on it and call it a day" doesn't really cut it anymore. You need to think about who's calling, what they're allowed to ask for, how often, in what patterns, and what to do when the pattern starts looking weird.